9. Lab 9 · Transactions : tout ou rien, et l’un après l’autre

Étape 9.1 · L’action et sa trace ensemble

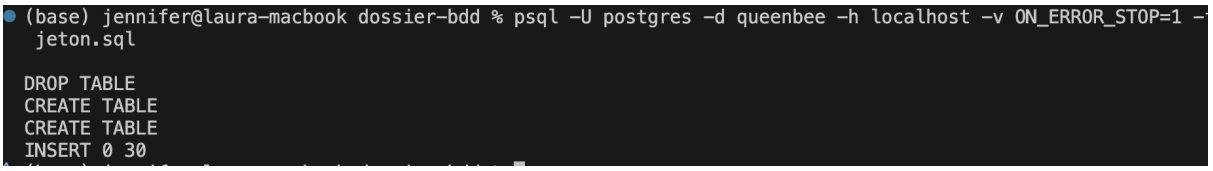
1. Création de la table temporaire journal_appli, écrivez-y récolte SN-CASA-011 validée par coord.sn, puis UPDATE recolte SET statut = 'validee' sur cette ruche, sans validee_par. Attendu : l’UPDATE est refusé par recolte_validation_tracee, mais le journal de l’application affirme la validation.

2. Comptez les lignes de journal_audit. Puis, entre BEGIN; et ROLLBACK; : la validation complète (avec validee_par et validee_le), un nouveau comptage, SELECT 1 / 0;, un comptage. Attendu : +1 dans la transaction, current transaction is aborted après l’erreur, et tout revenu après le ROLLBACK.

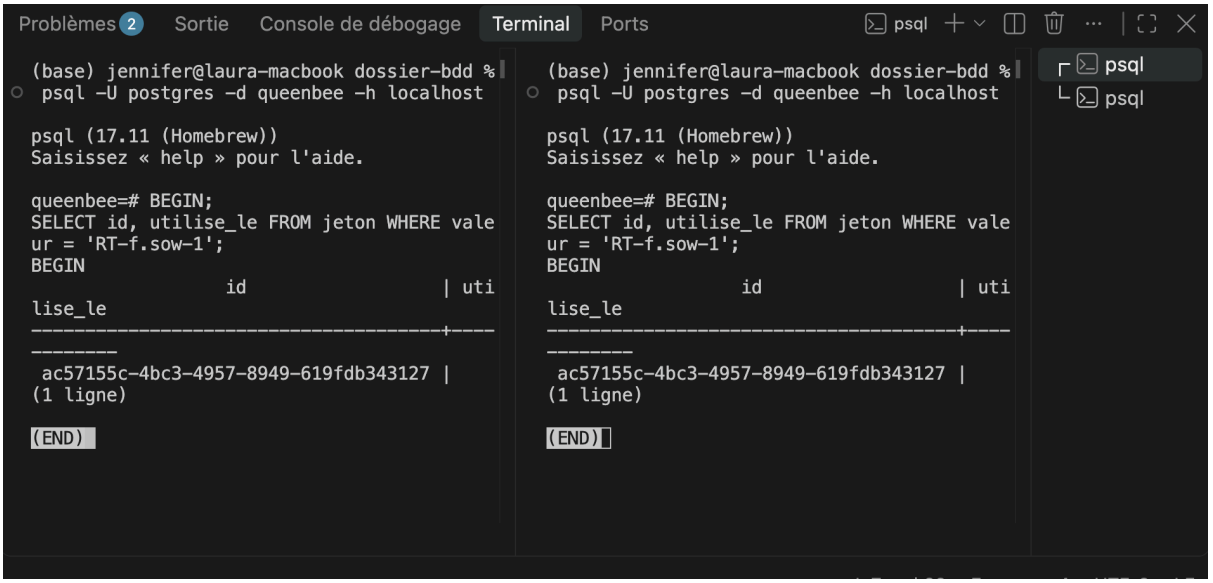
3. Dans VS Code, créez concurrence.md et notez ces deux résultats.

Étape 9.2 · La course au jeton, dans deux terminaux

1. Dans VS Code, créez jeton.sql : une table jeton (id, utilisateur_id vers utilisateur, valeur unique, expire_le, utilise_le), une table session_app (id, utilisateur_id, jeton_id vers jeton, ouverte_le par défaut clock_timestamp()), et trente jetons pour f.ba, de RT-f.ba-1 à RT-f.ba-30, valables un jour. Attendu : INSERT 0 30.



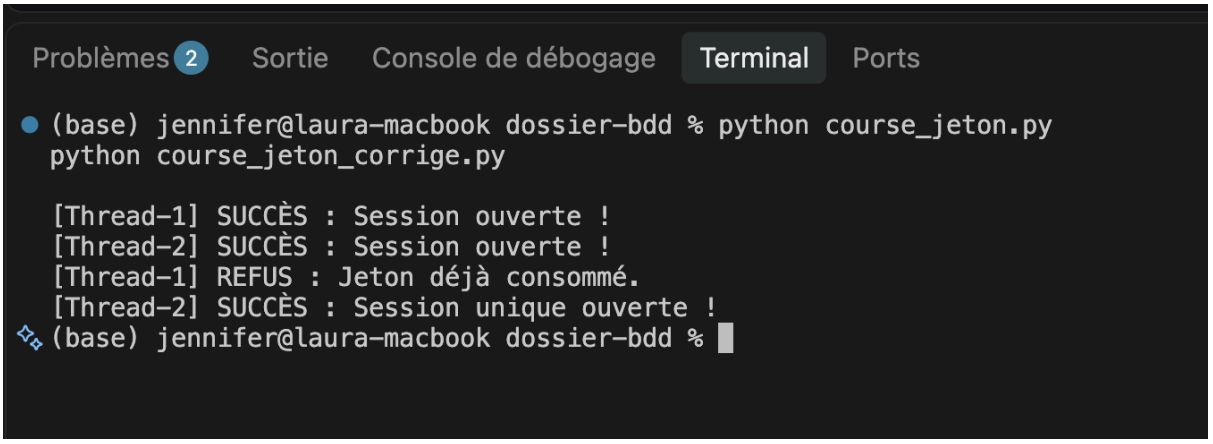
2. Ouvrez deux terminaux et jouez la course avec RT-f.ba-1, comme dans l'exemple : BEGIN, SELECT du jeton, UPDATE, INSERT INTO session_app … SELECT utilisateur_id, id FROM jeton WHERE valeur = 'RT-f.ba-1', COMMIT. Attendu : 2 sessions avec ce jeton.



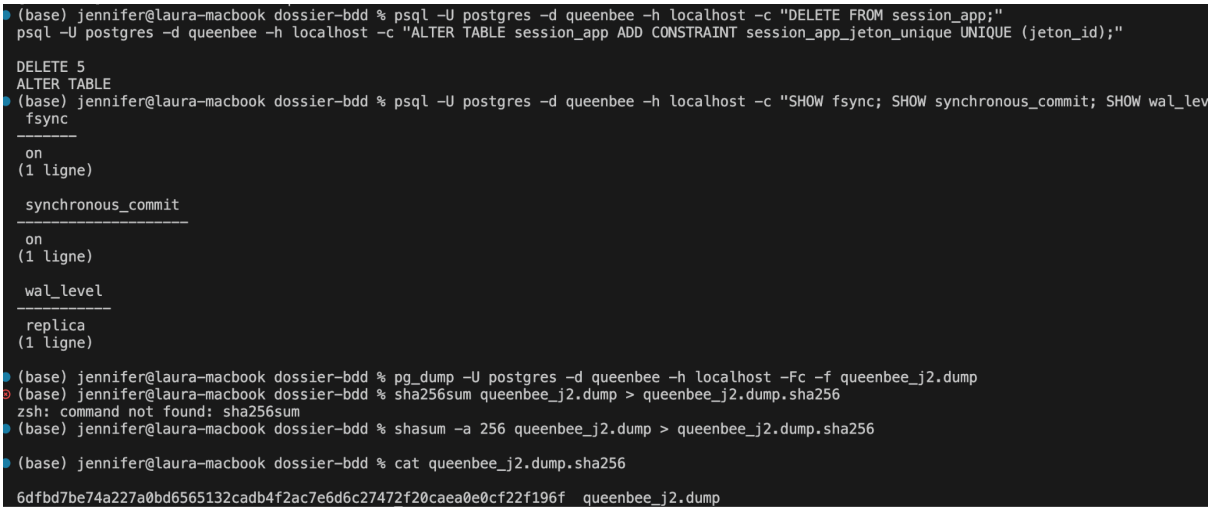


3. Recopiez dans concurrence.md le tableau des temps, avec ce que chaque terminal a répondu.

Étape 9.3 · La course par un programme



Étape 9.4 · Comprendre les quatre corrections



Étape 9.5 · Durabilité et sauvegarde

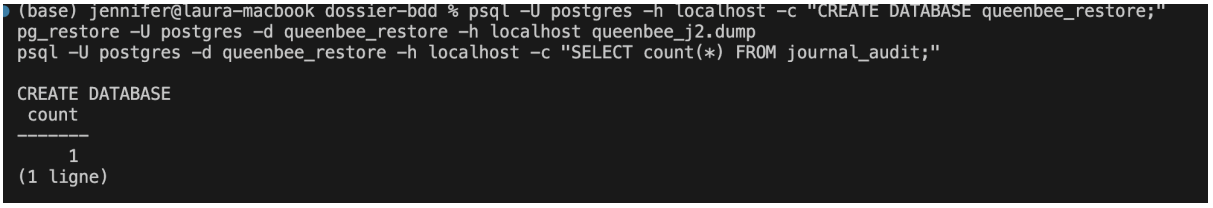
1. Vérifier les paramètres WAL :
psql -U postgres -d queenbee -h localhost -c "SHOW fsync; SHOW synchronous_commit; SHOW wal_level;"

2. Sauvegarder toute la base au format compressé :
pg_dump -U postgres -d queenbee -h localhost -Fc -f queenbee_j2.dump

3. Calculer l'empreinte SHA-256 (livrable obligatoire):
sha256sum queenbee_j2.dump > queenbee_j2.dump.sha256

4. Tester la restauration dans une base vierge:
psql -U postgres -h localhost -c "DROP DATABASE IF EXISTS queenbee_restore;"
psql -U postgres -h localhost -c "CREATE DATABASE queenbee_restore;"
pg_restore -U postgres -d queenbee_restore -h localhost queenbee_j2.dump

5. Vérifier le journal d'audit dans la base restaurée:
psql -U postgres -d queenbee_restore -h localhost -c "SELECT count(*) FROM journal_audit;"



10. Lab 10 · Revue de sécurité

Étape 10.1 · L'injection par le tri

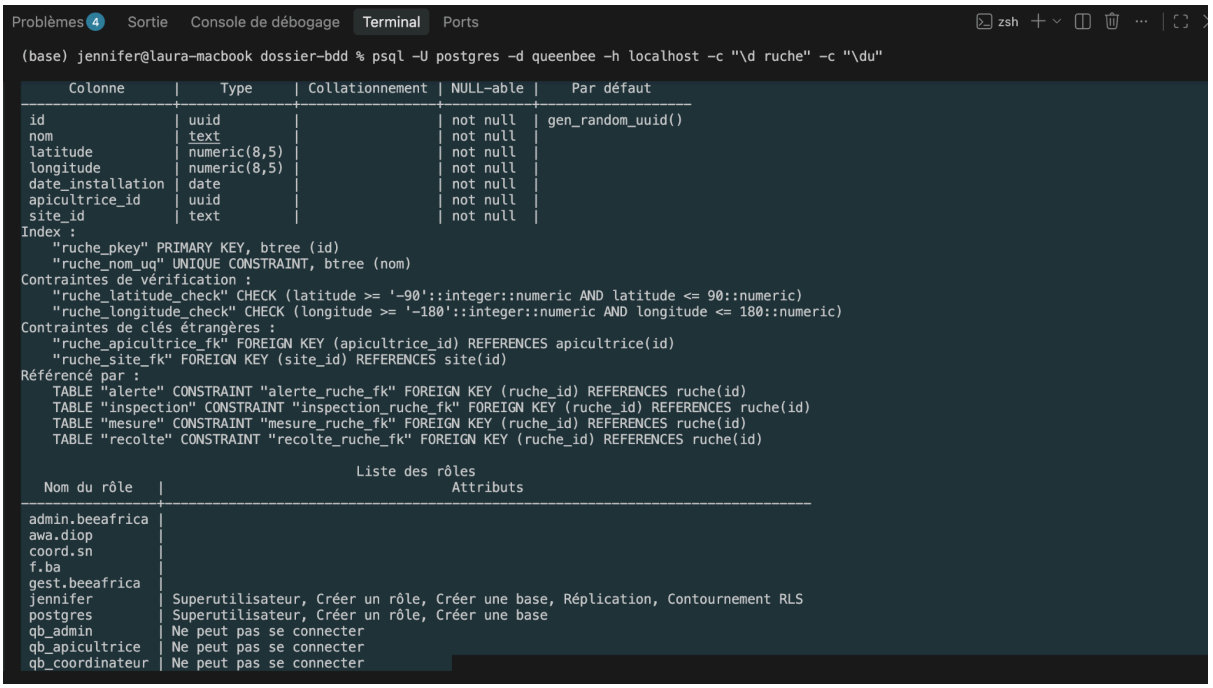
Captures de tous les tests d'attaques sur recherche_vuln.py et le test de sécurité sur recherche.py

```
(base) jennifer@laura-macbook dossier-bdd % python recherche_vuln.py
Site : SN-CASA
Trier par (code ou date_installation) : id
(UUID('02e8ffd3-e9ab-492f-9ac5-1827d3a25b9a'), datetime.date(2025, 3, 10), Decimal('-16.27250'))
(UUID('b5412afc-2633-40f7-88bc-0f1a993c8721'), datetime.date(2025, 6, 2), Decimal('-16.28000'))
(UUID('c2d33fee-1e06-4983-9bb0-b83eabb83cac'), datetime.date(2025, 3, 10), Decimal('-16.27200'))
(base) jennifer@laura-macbook dossier-bdd % python recherche_vuln.py
Site : SN-CASA
Trier par (code ou date_installation) : (SELECT telephone::int FROM apicultrice WHERE nom = 'Fatou Sow')
Traceback (most recent call last):
  File "/Users/jennifer/dossier-bdd/recherche_vuln.py", line 10, in <module>
    for row in conn.execute(sql, (site,)):
               ^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/opt/anaconda3/lib/python3.11/site-packages/psycopg/connection.py", line 304, in execute
    raise ex.with_traceback(None)
psycopg.errors.InvalidTextRepresentation: invalid input syntax for type integer: "+221 77 200 00 04"
(base) jennifer@laura-macbook dossier-bdd % python recherche_vuln.py
Site : SN-CASA
Trier par (code ou date_installation) : CASE WHEN (SELECT substr(telephone, 6, 2) FROM apicultrice WHERE nom = 'Fatou Sow') = '77' THEN id::text ELSE
 longitude::text END
(UUID('02e8ffd3-e9ab-492f-9ac5-1827d3a25b9a'), datetime.date(2025, 3, 10), Decimal('-16.27250'))
(UUID('b5412afc-2633-40f7-88bc-0f1a993c8721'), datetime.date(2025, 6, 2), Decimal('-16.28000'))
(UUID('c2d33fee-1e06-4983-9bb0-b83eabb83cac'), datetime.date(2025, 3, 10), Decimal('-16.27200'))
(base) jennifer@laura-macbook dossier-bdd % python recherche_vuln.py
Site : SN-CASA
Trier par (code ou date_installation) : CASE WHEN (SELECT substr(telephone, 6, 2) FROM apicultrice WHERE nom = 'Fatou Sow') = '78' THEN id::text ELSE
 longitude::text END
(UUID('c2d33fee-1e06-4983-9bb0-b83eabb83cac'), datetime.date(2025, 3, 10), Decimal('-16.27200'))
(UUID('02e8ffd3-e9ab-492f-9ac5-1827d3a25b9a'), datetime.date(2025, 3, 10), Decimal('-16.27250'))
(UUID('b5412afc-2633-40f7-88bc-0f1a993c8721'), datetime.date(2025, 6, 2), Decimal('-16.28000'))
(base) jennifer@laura-macbook dossier-bdd % python recherche_vuln.py
Site : SN-CASA
Trier par (code ou date_installation) : id; DROP TABLE journal_audit
Traceback (most recent call last):
  File "/Users/jennifer/dossier-bdd/recherche_vuln.py", line 10, in <module>
    for row in conn.execute(sql, (site,)):
               ^^^^^^^^^^^^^^^^^^^^^^^^^^
  File "/opt/anaconda3/lib/python3.11/site-packages/psycopg/connection.py", line 304, in execute
    raise ex.with_traceback(None)
psycopg.errors.SyntaxError: cannot insert multiple commands into a prepared statement
(base) jennifer@laura-macbook dossier-bdd % python recherche.py
Site : SN-CASA
Trier par (id ou date_installation) : (SELECT telephone::int FROM apicultrice WHERE nom = 'Fatou Sow')
Tri refusé : choisissez id ou date_installation.
(base) jennifer@laura-macbook dossier-bdd %
```

Étape 10.2 · La vue qui en dit trop

1-Vérification des noms exacts de mon schéma

2- Exposition des deux failles

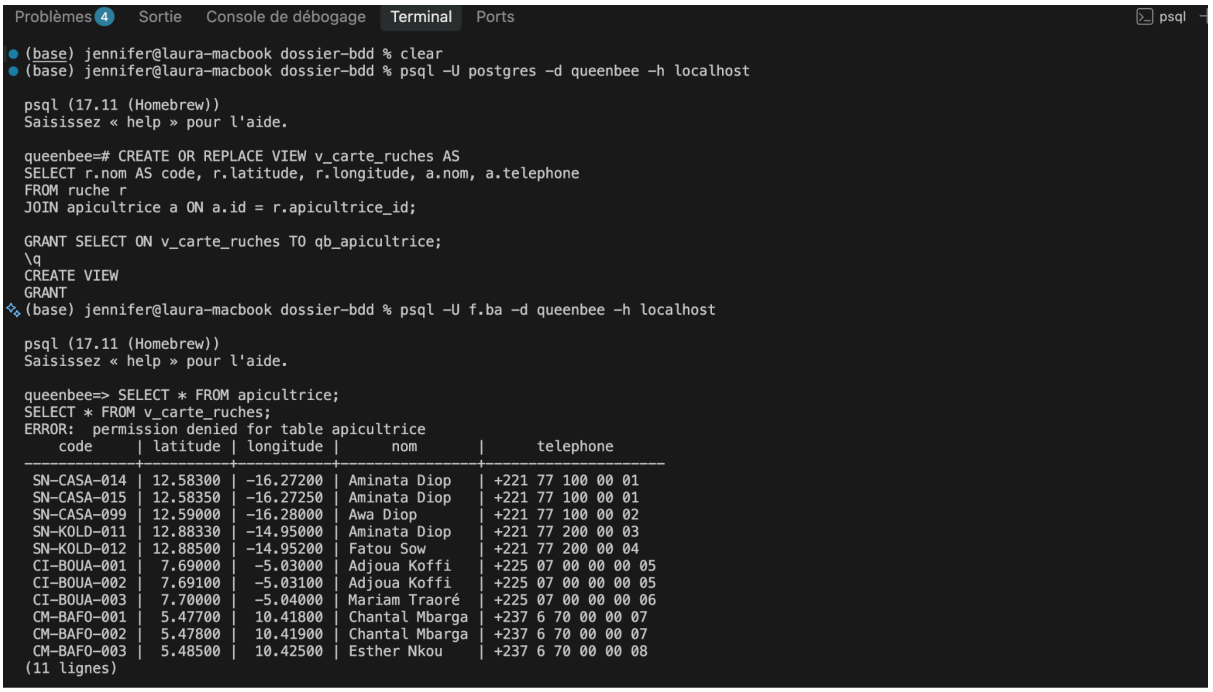


```
Problèmes 4  Sortie  Console de débogage  Terminal  Ports                                                    zsh

(base) jennifer@laura-macbook dossier-bdd % psql -U postgres -d queenbee -h localhost -c "\d ruche" -c "\du"

      Colonne      |     Type     | Collationnement | NULL-able |    Par défaut
-------------------+--------------+-----------------+-----------+-------------------
 id                | uuid         |                 | not null  | gen_random_uuid()
 nom               | text         |                 | not null  |
 latitude          | numeric(8,5) |                 | not null  |
 longitude         | numeric(8,5) |                 | not null  |
 date_installation | date         |                 | not null  |
 apicultrice_id    | uuid         |                 | not null  |
 site_id           | text         |                 | not null  |
Index :
    "ruche_pkey" PRIMARY KEY, btree (id)
    "ruche_nom_uq" UNIQUE CONSTRAINT, btree (nom)
Contraintes de vérification :
    "ruche_latitude_check" CHECK (latitude >= '-90'::integer::numeric AND latitude <= 90::numeric)
    "ruche_longitude_check" CHECK (longitude >= '-180'::integer::numeric AND longitude <= 180::numeric)
Contraintes de clés étrangères :
    "ruche_apicultrice_fk" FOREIGN KEY (apicultrice_id) REFERENCES apicultrice(id)
    "ruche_site_fk" FOREIGN KEY (site_id) REFERENCES site(id)
Référencé par :
    TABLE "alerte" CONSTRAINT "alerte_ruche_fk" FOREIGN KEY (ruche_id) REFERENCES ruche(id)
    TABLE "inspection" CONSTRAINT "inspection_ruche_fk" FOREIGN KEY (ruche_id) REFERENCES ruche(id)
    TABLE "mesure" CONSTRAINT "mesure_ruche_fk" FOREIGN KEY (ruche_id) REFERENCES ruche(id)
    TABLE "recolte" CONSTRAINT "recolte_ruche_fk" FOREIGN KEY (ruche_id) REFERENCES ruche(id)

                                    Liste des rôles
   Nom du rôle   |                                Attributs
-----------------+-----------------------------------------------------------------------------
 admin.beeafrica |
 awa.diop        |
 coord.sn        |
 f.ba            |
 gest.beeafrica  |
 jennifer        | Superutilisateur, Créer un rôle, Créer une base, Réplication, Contournement RLS
 postgres        | Superutilisateur, Créer un rôle, Créer une base
 qb_admin        | Ne peut pas se connecter
 qb_apicultrice  | Ne peut pas se connecter
 qb_coordinateur | Ne peut pas se connecter
```



```
Problèmes 4  Sortie  Console de débogage  Terminal  Ports                                                    psql

(base) jennifer@laura-macbook dossier-bdd % clear
(base) jennifer@laura-macbook dossier-bdd % psql -U postgres -d queenbee -h localhost

psql (17.11 (Homebrew))
Saisissez « help » pour l'aide.

queenbee=# CREATE OR REPLACE VIEW v_carte_ruches AS
SELECT r.nom AS code, r.latitude, r.longitude, a.nom, a.telephone
FROM ruche r
JOIN apicultrice a ON a.id = r.apicultrice_id;

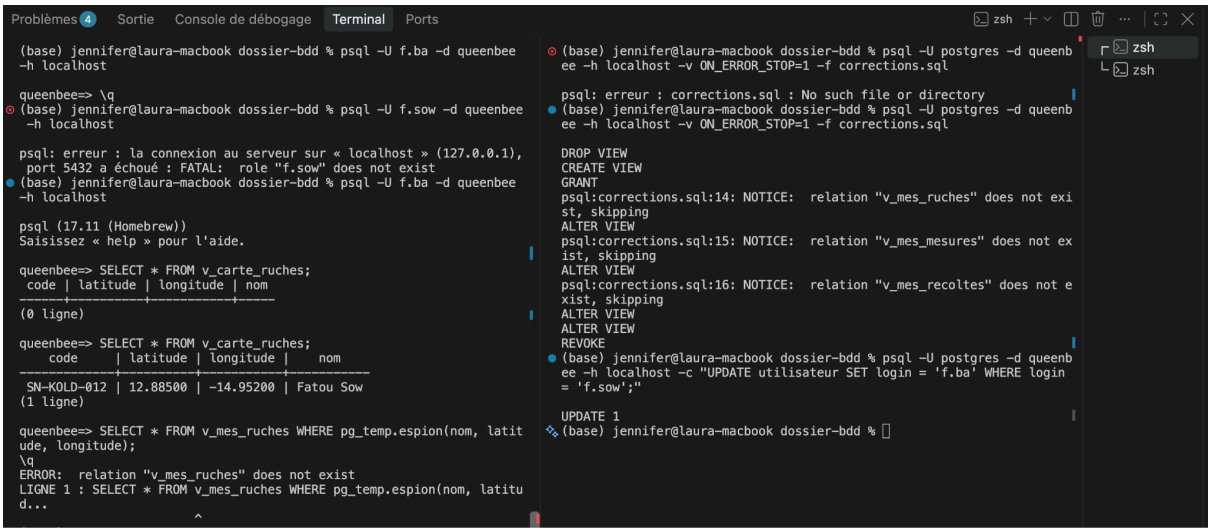
GRANT SELECT ON v_carte_ruches TO qb_apicultrice;
\q
CREATE VIEW
GRANT
(base) jennifer@laura-macbook dossier-bdd % psql -U f.ba -d queenbee -h localhost

psql (17.11 (Homebrew))
Saisissez « help » pour l'aide.

queenbee=> SELECT * FROM apicultrice;
SELECT * FROM v_carte_ruches;
ERROR:  permission denied for table apicultrice
    code     | latitude | longitude |      nom       |      telephone
-------------+----------+-----------+----------------+--------------------
 SN-CASA-014 | 12.58300 | -16.27200 | Aminata Diop   | +221 77 100 00 01
 SN-CASA-015 | 12.58350 | -16.27250 | Aminata Diop   | +221 77 100 00 01
 SN-CASA-099 | 12.59000 | -16.28000 | Awa Diop       | +221 77 100 00 02
 SN-KOLD-011 | 12.88330 | -14.95000 | Aminata Diop   | +221 77 200 00 03
 SN-KOLD-012 | 12.88500 | -14.95200 | Fatou Sow      | +221 77 200 00 04
 CI-BOUA-001 |  7.69000 |  -5.03000 | Adjoua Koffi   | +225 07 00 00 00 05
 CI-BOUA-002 |  7.69100 |  -5.03100 | Adjoua Koffi   | +225 07 00 00 00 05
 CI-BOUA-003 |  7.70000 |  -5.04000 | Mariam Traoré  | +225 07 00 00 00 06
 CM-BAFO-001 |  5.47700 |  10.41800 | Chantal Mbarga | +237 6 70 00 00 07
 CM-BAFO-002 |  5.47800 |  10.41900 | Chantal Mbarga | +237 6 70 00 00 07
 CM-BAFO-003 |  5.48500 |  10.42500 | Esther Nkou    | +237 6 70 00 00 08
(11 lignes)
```

```
queenbee=> CREATE FUNCTION pg_temp.espion(p_code text, p_lat numeric, p_lon numeric) RETURNS boolean
LANGUAGE plpgsql AS $$
BEGIN
    RAISE NOTICE 'FUITE GPS -> ruche: %, lat: %, lon: %', p_code, p_lat, p_lon;
    RETURN true;
END;
$$;
CREATE FUNCTION
queenbee=>
```

```
queenbee=> CREATE FUNCTION pg_temp.espion(p_code text, p_lat numeric, p_lon numeric) RETURNS boolean
LANGUAGE plpgsql AS $$
BEGIN
    RAISE NOTICE 'FUITE GPS -> ruche: %, lat: %, lon: %', p_code, p_lat, p_lon;
    RETURN true;
END;
$$;
CREATE FUNCTION
queenbee=>
```




```
(base) jennifer@laura-macbook dossier-bdd % psql -U f.ba -d queenbee
  -h localhost -c "CREATE TEMP TABLE test_temp (x int);"

  ERROR:  permission denied to create temporary tables in database "que
  enbee"
  LIGNE 1 : CREATE TEMP TABLE test_temp (x int);
                              ^
(base) jennifer@laura-macbook dossier-bdd %
```

Étape 10.3 · Auditer votre propre base

Lancement des contrôles techniques en psql

C1, C2 et C3

```
(base) jennifer@laura-macbook dossier-bdd % psql -U postgres -d queenbee -h localhost
psql (17.11 (Homebrew))
Saisissez « help » pour l'aide.

queenbee=# SELECT proname FROM pg_proc p
JOIN pg_namespace n ON n.oid = p.pronamespace
WHERE n.nspname = 'public' AND has_function_privilege('public', p.oid, 'EXECUTE');
 proname
---------
(0 ligne)

queenbee=# SELECT proname, proconfig FROM pg_proc p
JOIN pg_namespace n ON n.oid = p.pronamespace
WHERE n.nspname = 'public' AND prosecdef = true;
   proname   |            proconfig
-------------+----------------------------------
 audit_ligne | {"search_path=public, pg_temp"}
(1 ligne)

queenbee=# SELECT relname, reloptions FROM pg_class c
JOIN pg_namespace n ON n.oid = c.relnamespace
```

C3 et C10:

```
queenbee=# SELECT relname, reloptions
FROM pg_class c
JOIN pg_namespace n ON n.oid = c.relnamespace
WHERE n.nspname = 'public' AND relkind = 'v';SELECT conrelid::regclass AS table_, confrelid::regclass AS vers, conname, confdeltype
FROM pg_constraint WHERE contype = 'f' ORDER BY 1;
      relname      |       reloptions
-------------------+------------------------
 v_carte_ruches    | {security_barrier=true}
 v_export_bailleur |
 v_moi             | {security_barrier=true}
(3 lignes)

     table_      |    vers     |               conname               | confdeltype
-----------------+-------------+-------------------------------------+-------------
 cooperative     | site        | cooperative_site_fk                 | a
 apicultrice     | site        | apicultrice_site_fk                 | a
 ruche           | apicultrice | ruche_apicultrice_fk                | a
 ruche           | site        | ruche_site_fk                       | a
 utilisateur     | site        | utilisateur_site_fk                 | a
 utilisateur     | apicultrice | utilisateur_apicultrice_fk          | a
 adhesion        | apicultrice | adhesion_apicultrice_fk             | a
 adhesion        | cooperative | adhesion_cooperative_fk             | a
 mesure          | ruche       | mesure_ruche_fk                     | a
 inspection      | ruche       | inspection_ruche_fk                 | a
 inspection      | apicultrice | inspection_apicultrice_fk           | a
 recolte         | ruche       | recolte_ruche_fk                    | a
 recolte         | utilisateur | recolte_validee_par_fk              | a
 alerte          | ruche       | alerte_ruche_fk                     | a
 suivi_formation | apicultrice | suivi_formation_apicultrice_id_fkey | a
 suivi_formation | formateur   | suivi_formation_formateur_id_fkey   | a
 jeton           | utilisateur | jeton_utilisateur_id_fkey           | c
 session_app     | utilisateur | session_app_utilisateur_id_fkey     | c
 session_app     | jeton       | session_app_jeton_id_fkey           | c
(19 lignes)
```

Passer sous l'identité de f.ba

C4 : Vérifier que seules les données de f.ba sont visibles

```
queenbee=# SET ROLE "f.ba";
SET
queenbee=> SELECT * FROM v_carte_ruches;
SELECT * FROM v_moi;
    code     | latitude | longitude |    nom
-------------+----------+-----------+-----------
 SN-KOLD-012 | 12.88500 | -14.95200 | Fatou Sow
(1 ligne)

ERROR:  permission denied for view v_moi
queenbee=>
```

C5 : Vérifier que le journal d'audit est protégé

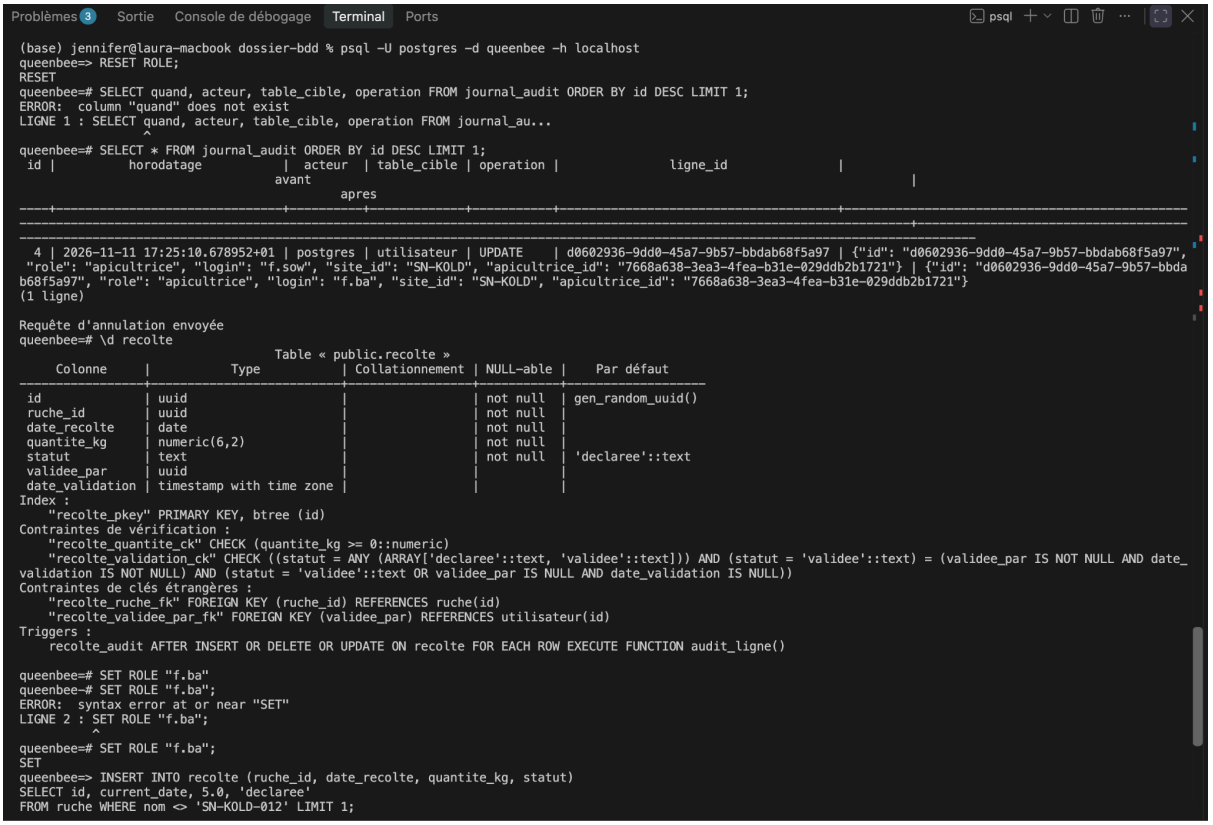
```
queenbee=> UPDATE journal_audit SET acteur = 'pirate';
DELETE FROM journal_audit;
TRUNCATE journal_audit;
ERROR:  permission denied for table journal_audit
ERROR:  permission denied for table journal_audit
ERROR:  permission denied for table journal_audit
```

C6 : Faire une action légitime et revenir en postgres pour lire le journal

C7 : Tenter de déclarer une récolte sur la ruche d'une autre apicultrice

C7: n’a pas reussi

```
queenbee=> SET ROLE "f.ba";
SET
queenbee=> INSERT INTO recolte (ruche_id, date_recolte, quantite_kg, statut) -- (Adapte les noms selon \d recolte)
SELECT id, current_date, 4.2, 'declaree'
FROM ruche WHERE nom = 'SN-KOLD-012';
ERROR:  permission denied for table recolte
queenbee=> INSERT INTO recolte (ruche_id, date_recolte, quantite_kg, statut) -- (Adapte les noms selon \d recolte)
SELECT id, current_date, 5.0, 'declaree'
FROM ruche WHERE nom <> 'SN-KOLD-012' LIMIT 1;
ERROR:  permission denied for table recolte
queenbee=>
```



```
Problèmes 3  Sortie  Console de débogage  Terminal  Ports                                                
```

```
queenbee=> RESET ROLE;
RESET
queenbee=# \i corrections.sql
DROP VIEW
CREATE VIEW
GRANT
psql:corrections.sql:14: NOTICE:  relation "v_mes_ruches" does not exist, skipping
ALTER VIEW
psql:corrections.sql:15: NOTICE:  relation "v_mes_mesures" does not exist, skipping
ALTER VIEW
psql:corrections.sql:16: NOTICE:  relation "v_mes_recoltes" does not exist, skipping
ALTER VIEW
ALTER VIEW
REVOKE
GRANT
GRANT
ALTER TABLE
DROP POLICY
CREATE POLICY
GRANT
queenbee=# SET ROLE "f.ba";
SET
queenbee=> INSERT INTO recolte (ruche_id, date_recolte, quantite_kg, statut)
SELECT id, current_date, 4.2, 'declaree'
FROM ruche WHERE nom = 'SN-KOLD-012';
INSERT 0 1
queenbee=> INSERT INTO recolte (ruche_id, date_recolte, quantite_kg, statut)
SELECT id, current_date, 5.0, 'declaree'
FROM ruche WHERE nom <> 'SN-KOLD-012' LIMIT 1;
ERROR:  new row violates row-level security policy for table "recolte"
```

Contrôle C8 : Vérifier qu'un jeton ne sert qu'une seule fois

```
queenbee=# \q
(base) jennifer@laura-macbook dossier-bdd % python course_jeton.py

 [Thread-2] SUCCÈS : Session ouverte !
 Exception in thread Thread-1 (attaquer):
 Traceback (most recent call last):
   File "/opt/anaconda3/lib/python3.11/threading.py", line 1045, in _bootstrap_inner
     self.run()
   File "/opt/anaconda3/lib/python3.11/threading.py", line 982, in run
     self._target(*self._args, **self._kwargs)
   File "/Users/jennifer/dossier-bdd/course_jeton.py", line 26, in attaquer
     cur.execute("INSERT INTO session_app (utilisateur_id, jeton_id) VALUES (%s, %s)", (user_id, jeton_id))
   File "/opt/anaconda3/lib/python3.11/site-packages/psycopg/cursor.py", line 117, in execute
     raise ex.with_traceback(None)
 psycopg.errors.UniqueViolation: duplicate key value violates unique constraint "session_app_jeton_unique"
 DETAIL:  Key (jeton_id)=(265d2dc2-9db8-48e8-b4c5-2724fe7bb187) already exists.
```

C9 : Vérifier l'absence de concaténation (+ ou f") dans tes scripts sécurisés

C11 : Vérifier l'absence de mot de passe en dur dans le dépôt

```
(base) jennifer@laura-macbook dossier-bdd % grep -E '(\+|f")' recherche.py course_jeton_corrige.py
course_jeton_corrige.py:                print(f"[{nom}] SUCCÈS : Session unique ouverte !")
course_jeton_corrige.py:                print(f"[{nom}] REFUS : Jeton déjà consommé.")
(base) jennifer@laura-macbook dossier-bdd % git grep -i password
roles.sql:      EXECUTE format('CREATE ROLE %I LOGIN PASSWORD %L IN ROLE %I', p.nom, p.mdp, p.groupe);
(base) jennifer@laura-macbook dossier-bdd %
```

Contrôle C12 : Reconstruction de la base

Ce contrôle est déjà vérifié par nos tests précédents : la base se reconstruit proprement, mais l'échec partiel de role.sql sur r.code constitue ton **constat R1** dans rapport_revue.md (corrigé via corrections.sql).